AEGIS-CARE / VERSION 5.0

Post-incident recovery for clinical AI memory

Research, product, and validation brief

When a clinical AI memory is found to be wrong, AEGIS-Care maps the downstream blast radius, confirms causal influence inside each authorised runtime, rebuilds safe state from FHIR, and prevents resurrection.

108	12	1.000	PASS
paired runs	incidents	CARE recall / precision	8-artifact integrity

EXTERNAL-FORMAT MECHANISM VALIDATION · SYNTHETIC FHIR ONLY

Research prototype · Not for diagnosis, treatment, patient care, or compliance certification

Executive decision

The strongest version of this project is not “another poisoning detector.” It is a **post-incident recovery control plane for persistent clinical AI memory**.

That position matters because detection alone does not answer the operational question: after one record association, copied fact, restricted fragment, or superseded measurement is withdrawn, which derived memories can still affect later work—and how can they be repaired without either reading every patient record centrally or wiping every useful memory?

AEGIS-Care v5 is now a complete, runnable answer to that mechanism question. It has:

- a role-separated FHIR sandbox and append-only memory ledger;
- four causal incident families and nine paired recovery conditions;
- the CARE loop: candidate discovery, local attribution, clean recompilation, enforcement;
- public Synthea FHIR ingestion with native-reference normalisation;
- receiver/incident-scoped support fingerprints for missing-lineage recovery;
- signed recovery certificates and resurrection probes;
- a SHA-256-bound evidence package with an independent verifier;
- an evidence-first reviewer dashboard; and
- 161 passing automated tests, plus one intentionally skipped optional live-model test.

The final public-data run completed **108 paired condition runs across 12 incidents**. Full CARE achieved **0.000 residual wrong-patient harm, 1.000 descendant recall, 1.000 precision, 1.000 benign-state retention, 0.000 unauthorised exposure, and 0.000 resurrection rate**. Those are mechanism results on fully synthetic records, not estimates of hospital or patient benefit.

Why this problem deserves serious attention

Clinical agents increasingly operate over longitudinal records, tools, and persistent state. The safety problem is therefore no longer confined to a single generated answer. A wrong association can be copied into a handover, compressed into a summary, reused by a later session, and remain active after the original entry is deleted.

Current clinical-agent benchmarks demonstrate that tool-using record work is already hard. MedAgentBench evaluates 300 tasks over 100 synthetic patient records with more than 700,000 data elements; its reported best agent completed 69.67% of tasks. That benchmark establishes the need for realistic EHR task evaluation, but it is not itself a post-incident recovery benchmark.

The broader assurance literature also points toward lifecycle governance rather than a single accuracy score:

- FUTURE-AI frames trustworthy and deployable healthcare AI around fairness, universality, traceability, usability, robustness, and explainability.
- DECIDE-AI focuses reporting for early-stage clinical evaluation of AI decision-support systems.
- TRIPOD+AI strengthens transparent reporting for prediction-model studies using machine learning.
- The NIST Generative AI Profile provides cross-sector risk-management actions for generative AI across the lifecycle.
- HL7 FHIR R4 AuditEvent formalises security-event recording and explicitly relates audit records to Provenance—useful foundations for a recovery control plane, though not a recovery algorithm by themselves.

The research frontier is moving quickly. Recent work on memory provenance laundering, secure memory sanitisation and recovery, and memory-security benchmarking raises the novelty bar. AEGIS-Care should therefore make a precise contribution claim: **privacy-bounded, resurrection-resistant post-incident recovery for role-separated clinical memory under incomplete provenance**, supported by paired causal evaluation.

The product thesis

The operational promise

Give an incident responder one confirmed bad memory version. AEGIS-Care should return:

1. the bounded set of memories that may have inherited it;
2. signed local verdicts identifying which were actually influenced;
3. repaired or safely quarantined replacements;
4. proof that clean state was retained;
5. proof that the withdrawn versions cannot be retrieved or reintroduced; and
6. an evidence package that an independent reviewer can verify.

Why CARE is materially different

Stage	Operational function	Safety boundary
C — Candidate discovery	Traverse visible lineage, then nominate missing-edge candidates using scoped sketches and support fingerprints	Nomination cannot change state
A — Attribution	Replay the candidate locally without suspected influence	Raw clinical text never reaches the coordinator
R — Recompilation	Rebuild from trusted FHIR and verified clean support	Missing recipe/support fails closed to quarantine
E — Enforcement	Tombstone withdrawn versions and arm a resurrection firewall	Recovery remains enforced after the incident closes

The design deliberately separates **finding something similar** from **proving it was caused by the incident**. This is why the sketch-only baseline reaches perfect recall but retains only 0.2679 of clean state in the public-data experiment, while full CARE reaches perfect recall and retains all clean state.

What changed in version 5

1. External FHIR evidence instead of a closed generator loop

The new loader accepts FHIR JSON files, directories, and zip archives; samples complete patient-bearing bundles; normalises `urn:uuid` references; records source hashes, profiles, ignored resource types, and validation errors; and feeds the same sandbox API used by the internal fixture.

The final run used the public Synthea sample-data repository, generated by the Synthea synthetic-patient simulator. It loaded:

- 10 patient bundles;
- 3,623 supported FHIR resources;
- 2,611 Observations, 297 Conditions, 434 Encounters, and 271 MedicationRequests;
- 7,003 rewritten native UUID references;
- zero unresolved UUID references; and
- zero loader validation errors.

Only resource shapes used by the prototype are retained. Medication requests are marked simulation-only and are never executed.

2. Scoped support fingerprints

The first external iteration found a stale-fact case where targeted provenance loss hid the edge and corrected prose was too different for ordinary semantic matching. Version 5 mints at most 16 opaque support tokens from the FHIR resource identifiers consumed by a seed.

These tokens are:

- keyed to one incident and one receiving runtime;
- used only for local overlap matching;
- never sufficient to authorise repair;
- omitted from the public API, which exposes only their count; and
- still subject to mandatory counterfactual attribution.

Attribution then exposed a second issue: the benchmark had corrected an arbitrary historical duplicate-code observation rather than the value the memory actually asserted. The F4 constructor now selects the exact asserted resource/value pair. This failure-driven sequence is valuable evidence of the separation between discovery and causal confirmation.

3. Cryptographically bound evidence

Every external-validation package records the command, data provenance and hashes, runtime and package versions, exact metrics, limitations, and SHA-256 of each report/table/figure. The verifier detects tampering and the dashboard reads the same manifest.

4. Evidence-first reviewer experience

The dashboard now opens as a recovery command center rather than a generic demo. Its Evidence Center leads with:

- a three-tier claim ladder;
- the latest full-CARE metrics;
- the evidence integrity seal;
- external data provenance;
- standards/research alignment; and
- non-negotiable limitations and next gates.

Final external-format result

Condition	RWH ↓	Recall ↑	Precision ↑	BSR ↑	RTS ↑	UER ↓	DRR ↓
A — no recovery	0.2500	0.0000	1.0000	1.0000	0.7500	0.1000	1.0000
B — delete seed only	0.2500	0.0000	1.0000	1.0000	0.7500	0.0833	1.0000
C — full reset	0.0000	1.0000	0.2778	0.0000	1.0000	0.0000	1.0000
D — lineage quarantine	0.1667	0.4444	0.9167	0.9792	0.8333	0.0486	0.0000
E — lineage replay	0.1667	0.4444	0.9167	1.0000	0.8333	0.0463	0.0000
F — sketch-only quarantine	0.0000	1.0000	0.3444	0.2679	1.0000	0.0000	0.0000
G — central raw-content oracle	0.0000	1.0000	0.7500	0.8646	1.0000	1.0000	1.0000
H — complete private graph	0.0000	1.0000	1.0000	1.0000	1.0000	0.0000	1.0000
I — full CARE	**0.0000**	**1.0000**	**1.0000**	**1.0000**	**1.0000**	**0.0000**	**0.0000**

Interpretation:

- Deleting only the seed leaves every descendant active.
- Full reset removes harm by destroying all useful clean memory.
- Provenance-only recovery collapses under missing edges.
- Similarity-only recovery finds the contamination but acts on too much clean state.
- A central oracle recovers well by violating the project’s privacy boundary.
- Full CARE is the only non-oracle condition in this experiment that simultaneously reaches zero residual harm, perfect recall and precision, complete clean-state retention, zero unauthorised exposure, and zero resurrection.

The evidence manifest independently verifies eight artifacts. The complete regression run reports **161 passed, one skipped** in 258.29 seconds. JavaScript syntax, the live health and system routes, the evidence endpoint, and served dashboard markup were also checked.

Evidence ladder: what may and may not be claimed

Tier 1 — controlled mechanism evidence: achieved

- deterministic causal incident generation;
- paired baselines on frozen snapshots;
- complete safety and termination invariants;
- explicit privacy attacks and released-field audit;
- resurrection probes and signed recovery certificate; and
- reproducible tables, figures, and negative results.

Tier 2 — external FHIR-format evidence: achieved on synthetic data

- independent public generator;
- FHIR R4/US Core-shaped records;
- native-reference normalisation;
- all four incident families and nine recovery conditions; and
- bound, independently verifiable evidence artifacts.

Tier 3 — clinical workflow evidence: not achieved and not claimed

The project has not been evaluated on real patients, in a hospital workflow, with clinician adjudication, against patient outcomes, or under production governance. It is not a medical device, compliance certification, or recommendation engine.

Known risks and honest limitations

1. **Synthetic data only.** Synthea improves source independence, not clinical realism in every specialty or institution.
2. **Deterministic composer by default.** This is ideal for causal reproducibility but does not measure counterfactual stability in an open-ended LLM.
3. **Membership inference remains measurable.** The existing audit reports +0.286 membership advantage for the capsule/sketch interface. Receiver scoping prevents cross-recipient linkage in the tested attack, but no formal privacy guarantee is claimed.
4. **Support fingerprints add metadata exposure.** They are bounded, opaque, scoped, and API redacted, but should be replaced or strengthened with a formally analysed local/private construction before real deployment.
5. **Local policy overlay.** F3 introduces a deterministic restricted-field overlay because public Synthea data does not encode this project's institution-specific role policy.
6. **No live interoperability proof.** The loader accepts FHIR files; it has not been tested as a SMART-on-FHIR app, subscribed to production events, or integrated with an IHE ATNA audit repository.
7. **Thresholds are frozen research parameters.** They are not clinically calibrated.
8. **Browser visual automation was unavailable in this environment.** Static JavaScript, CSS/markup presence, live routes, and API behavior passed; a human visual pass remains in the release checklist.

The roadmap that can turn this into a serious research programme

Gate A — benchmark generalisation

- Pin MedAgentBench and all dependencies in a reproducible container.
- Add held-out task templates and patients not used in threshold selection.
- Run at least one open-weight model at temperature zero and repeated seeds.
- Measure replay instability separately from recovery failure.
- Publish every skipped/invalid incident and every negative result.

Exit criterion: full CARE improves recall over provenance-only recovery under matched edge loss without materially worsening precision, BSR, or privacy exposure.

Gate B — privacy hardening

- Threat-model support fingerprints alongside semantic sketches.
- Compare local-only set intersection, private set intersection, keyed Bloom filters, and differential-privacy/noise mechanisms.
- Expand membership, attribute, intersection, timing, and multi-incident linkage attacks.
- Rotate incident keys and enforce expiry/erasure of forensic indexes.

Exit criterion: predefined leakage thresholds pass under an external red-team protocol, with utility/privacy trade-offs reported rather than hidden.

Gate C — workflow and governance pilot

- Map AEGIS events to FHIR AuditEvent and Provenance resources.
- Add SMART-on-FHIR authorization and an IHE ATNA-compatible audit export.
- Conduct a silent, non-interventional simulation with synthetic or institution-approved de-identified cases.
- Have two independent clinicians adjudicate contamination, hard negatives, and repair acceptability; report agreement and disagreements.
- Pre-register endpoints and stopping rules using DECIDE-AI/FUTURE-AI-aligned reporting.

Exit criterion: clinicians can understand, contest, and resolve every recovery decision without exposing unauthorised raw content.

Gate D — prospective clinical study

This gate requires institutional sponsorship, ethics/governance review, security review, data-protection assessment, and a separate clinical protocol. No autonomous action should be permitted. The first prospective endpoint should be recovery correctness and workflow burden—not patient benefit—unless the study is powered and governed for clinical outcomes.

Recommended public narrative

One line: AEGIS-Care is the post-incident recovery layer for AI systems that remember clinical records.

Thirty seconds: Clinical AI can carry one bad fact across sessions even after the original memory is deleted. AEGIS-Care maps the downstream blast radius, confirms influence inside each authorised runtime, rebuilds safe memories from FHIR, and blocks resurrection. It has a complete paired benchmark, an independently hash-verified evidence package, and a public Synthea validation path. It is a research prototype, not a clinical product.

What not to say: Do not call the public-data result “clinically validated,” do not imply HIPAA/GDPR/DPDP certification, and do not claim patient benefit. The project becomes more credible—not less—when each claim is tied to the correct evidence tier.

Reproduce the result

```
bash
pip install -r requirements.txt

python -m aegis_care.cli demo
python -m aegis_care.cli external-validate \
  --fhir synthea_sample_data_fhir_latest.zip \
  --limit-patients 10 \
  --out results/external_validation
pytest -q
python -m aegis_care.cli serve
```

Then inspect:

- `results/external_validation/EXTERNAL_VALIDATION.md`
- `results/external_validation/evidence_manifest.json`
- `results/external_validation/results.json`
- the dashboard Evidence Center at `http://127.0.0.1:8000`

The authoritative machine-readable evidence is the manifest plus its bound artifacts. This brief is a decision aid, not a substitute for rerunning the package.